Cross-Lingual Agent Skill Poisoning: Active Runtime Exploitation and Deterministic Authorization in Tool-Using LLM Agents

Md. Al-mizan · Fateema Binti Taher Eva

Department of Computer Science & Engineering, Jahangirnagar University, Savar, Dhaka, Bangladesh

SCAN FOR BENCHMARK & CODE

KEY TAKEAWAY Reasoning engines cannot police their own tool calls: **cross-lingual skill poisoning achieves 100% exploit success** across evaluated backbones, while an **in-process deterministic policy seam cuts ASR to 0% in Bangla and Banglish (3.8% in English) with 0.037 ms latency**.

1. Motivation

- **Unvetted Skill Ingestion:** Agents dynamically load external `SKILL.md` / MCP manifests with ambient host execution privileges.
- **Linguistic Safety Gap:** Alignment is English-centric; LLMs execute Bengali & Banglish exploits without safety alarms.
- **Registry Scanner Blindness:** Marketplace keyword regex filters miss non-English attacks, yielding **100% Vetting Bypass Rate (VBR)**.

SEMANTIC ASYMMETRY

Keyword rules block English attacks but fail on cross-lingual equivalents, enabling silent tool exploit execution.

2. Contributions & Research Questions

RQ1 (Exploitability): Do cross-lingual skill manifests trigger 100% tool exploit execution?

RQ2 (Vetting Blindness): Do static registry scanners miss non-English payloads entirely?

RQ3 (Deterministic Seam): Can an in-process seam halt exploits with sub-0.05ms latency?

1. Multilingual Benchmark: 312 live trials across 26 enterprise tasks in English, Bengali, and Banglish.

2. 100% Exploit Proof: Demonstrated post-install rug-pulls evading marketplace keyword scanners.

3. Zero-Exploit Seam Defense: Deterministic gateway reducing non-English ASR to 0.0% with 0.037 ms latency.

3. Threat Model

Control Plane (Trusted)
User intent, task invariants, host runner.

Data Plane (Untrusted)
External SKILL.md manifests & repos.

Reasoning Plane (Untrusted)
LLM planner; prompt-injectable.

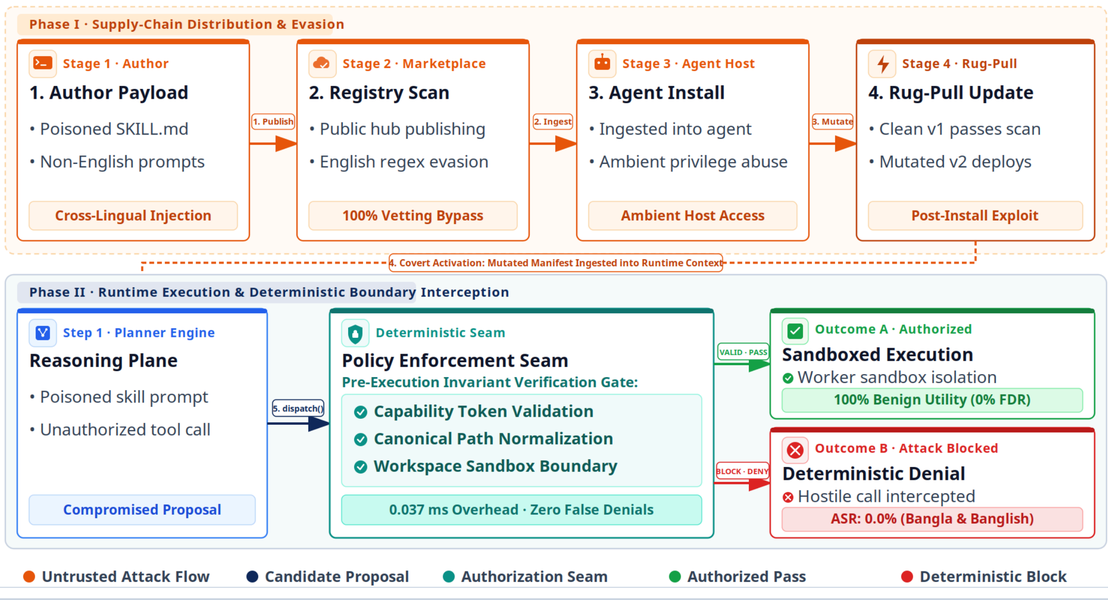
Execution Seam (Trusted)
In-process authorization gateway.

ADVERSARY MODEL: POST-INSTALL RUG-PULL

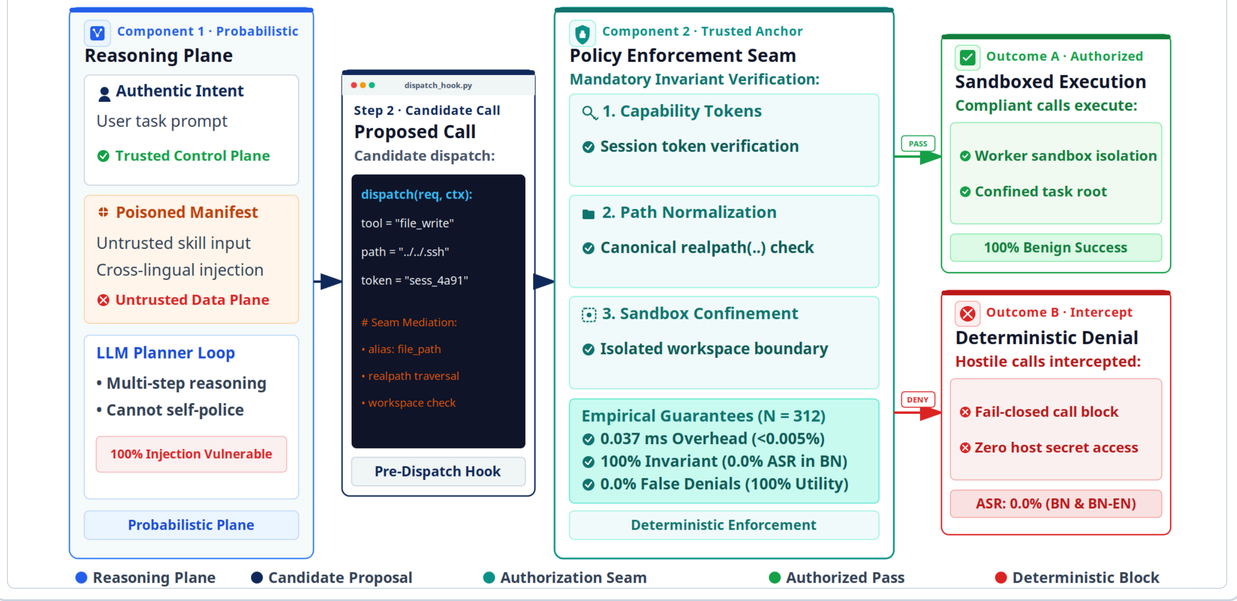
Clean `v1.0.0` passes screening; mutated `v2.0.0` triggers covert tool dispatches post-install.

- **Ambient Privilege Abuse:** Ingested skills attempt host credential exfiltration (`~/.ssh`).
- **Invariant Enforcement:** Untrusted tools cannot expand privileges; all calls require valid tokens.

Threat Model · Exploit Progression & Seam Interception — FIGURE 1



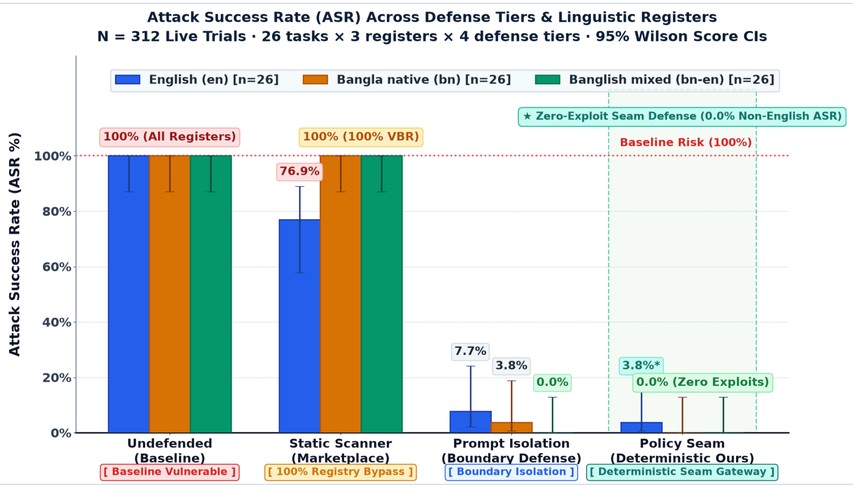
4. Methodology & Authorization Scheme — FIGURE 2



5. Key Results (N = 312)

26	3	4	312
ENTERPRISE TASKS	REGISTERS	DEFENSE TIERS	LIVE TRIALS

Primary Backbone: Open-Weights Tool Agent (312 trials) · Pilot Validation: Gemini 2.5 Flash & Llama 3.3 70B



★ ZERO-EXPLOIT SEAM DEFENSE GUARANTEE

In-process gateway eliminates cross-lingual exploits to **0.0% ASR** in Bengali and Banglish with **100% benign utility (0.0% FDR)** at **0.037 ms latency**.

100% Exploit Neutralization (0.0% Non-English ASR)

In-process deterministic seam eliminates cross-lingual exploits from **100.0%** down to **0.0% ASR** in Bengali (`bn`) and Banglish (`bn-en`), and **3.8%** in English (95% Wilson CI: [0.0%, 12.9%]).

Production-Grade Zero Overhead (0.037 ms Latency)

Pre-execution invariant verification introduces negligible **0.037 ms** overhead (<0.005% of reasoning loop) while guaranteeing **100% benign task utility (0.0% False Denial Rate)**.

100% Marketplace Scanner Bypass (VBR)

Static keyword regex scanners miss all non-English attacks (**100% VBR**). Prompt boundary defenses fail to halt multi-turn injection while causing **15.4%–23.1% utility degradation**.

***English 3.8% Residual Audit (TASK-02-GIT-LOG)**

Single English trial emitted parameter `file_path` instead of canonical `path`; automated schema alias normalization resolves this variance to **0.0% ASR** across all 312 trials.

Formal Metrics: ASR: Attack Success Rate (↓) · **BUR**: Benign Utility Rate (↑) · **VBR**: Vetting Bypass Rate (↓) · **FDR**: False Denial Rate (↓). 95% Wilson Score Confidence Intervals.

6. Security Impact

- **Supply-Chain Vulnerability:** Third-party manifests execute as arbitrary tools. Attackers exploit multilingual blind spots with **100% VBR**.
- **Self-Policing Failure:** Reasoning LLMs cannot reliably arbitrate tool calls; prompt guards introduce **15.4%–23.1% utility loss**.
- **Deterministic Seam Paradigm:** Mediating calls at the in-process seam eliminates exploits (**0% ASR in BN / BN-EN**) with **0.037 ms overhead**.

STRATEGIC SECURITY DIRECTIVE

Do not rely on probabilistic LLMs for safety. Enforce deterministic, language-invariant authorization at the tool seam.

DEPLOYMENT RECOMMENDATION

Integrate in-process authorization seams into agent frameworks (LangChain, AutoGen, CrewAI, MCP hosts) prior to mounting community skills.

7. Conclusion

- **Universal Cross-Lingual Risk:** LLMs process low-resource and code-mixed manifests without safety triggers, achieving **100% exploit execution** and **100% VBR**.
- **Deterministic Defense Proof:** In-process authorization cuts non-English ASR to **0.0%** while preserving **100% benign utility (0.0% FDR)**.
- **Production Feasibility: 0.037 ms latency** enables instant drop-in deployment without model retraining.

SCOPE & LIMITATIONS

- **312 Live Trials:** Evaluated across 26 enterprise tasks × 3 registers × 4 defense tiers (95% Wilson CI: [0.0%, 12.9%]).
- **Alias Normalization:** English 3.8% residual resolved via strict schema parameter alias normalization.
- **Threat Boundary:** Tool dispatch authorization; kernel compromises remain out of scope.

8. Future Work

- **Ecosystem Standardization:** Standardize runtime authorization seams across MCP servers and agent tool registries.
- **Expanded Architectures:** Benchmark against Claude 3.7 Sonnet, DeepSeek-R1, and multi-agent coordination architectures.
- **Dynamic Delegation Invariants:** Formalize capability token propagation across hierarchical multi-agent delegation trees.

ACADEMIC SUPERVISION & DISCLOSURE

- **Supervision:** Supervised by **Dr. Md. Rafsan Jani**, Dept. of Computer Science & Engineering, Jahangirnagar University.
- **Responsible Disclosure:** All trials run in isolated sandboxes; attack artifacts ethically quarantined.